Rúbrica de Evaluación

Reporte de Proceso · Examen Final · Curso de Hacking con Inteligencia Artificial

El entregable **no** es un reporte ejecutivo ni un reporte técnico de pentest. Es un **reporte de proceso**: cómo resolviste cada paso del laboratorio, con qué herramientas, y sobre todo **cómo usaste la inteligencia artificial** para avanzar (prompts, validación de sus respuestas, iteración). Se evalúa el método y la evidencia reproducible, no solo haber capturado las flags.

Puntaje total: **100 puntos**. Objetivo: el laboratorio de **examen** (target con su IP / puerto asignado). Cada nivel otorga un **puntaje fijo** (sin rangos): el campo se cumple a ese nivel o no, para una corrección objetiva.

Resumen de categorías

#	Categoría	Puntos
1	Reconocimiento y enumeración	**15**
2	Acceso inicial (foothold)	**20**
3	Escalada de privilegios	**15**
4	Uso de inteligencia artificial	**20**
5	Herramientas: selección y justificación	**10**
6	Evidencias y reproducibilidad	**10**
7	Claridad y estructura del reporte	**10**
	TOTAL	**100**

Puntaje máximo alcanzable: 100 puntos. Todos los campos en nivel Completo suman exactamente 100 (15 + 20 + 15 + 20 + 10 + 10 + 10 = 100). El bonus opcional no supera este tope.

1. Reconocimiento y enumeración — 15 pts

Descubrir y entender la superficie del target antes de atacar: puertos, servicios, versiones y pistas.

Requisitos para el puntaje completo:

- Documenta el escaneo (p. ej. `nmap -sV`) con puertos, servicios y versiones encontrados.
- Interpreta los resultados: explica qué significan (p. ej. una versión en el banner que apunta a un CVE conocido).
- Enumera el contenido relevante de cada servicio: endpoints web, archivos, comentarios en el código fuente, pistas.

Nivel	Puntos	Qué debe mostrar
Completo	**15**	Recon metódico: servicios + versiones + interpretación y todas las pistas documentadas.
Parcial	**10**	Identifica servicios pero no interpreta versiones ni encuentra/documenta las pistas.
Mínimo	**5**	Escaneo suelto, sin método ni lectura de resultados.
Ausente	**0**	No hay recon documentado.

2. Acceso inicial (foothold) — 20 pts

Explotar la vulnerabilidad de entrada hasta lograr ejecución/acceso y la primera flag.

Requisitos para el puntaje completo:

- Identifica la vulnerabilidad de entrada y explica **por qué** es vulnerable (causa raíz).
- Reproduce la explotación paso a paso, con los comandos o payloads exactos.
- Obtiene ejecución/shell y captura la **user flag**, con evidencia.

Nivel	Puntos	Qué debe mostrar
Completo	20	Explotación entendida y reproducible, user flag con evidencia, causa raíz explicada.
Parcial	12	Logra acceso pero explica poco el porqué o faltan pasos para reproducirlo.
Mínimo	6	Intento parcial, sin shell ni flag.
Ausente	0	No logra ni documenta acceso.

3. Escalada de privilegios — 15 pts

Pasar del usuario inicial a root, entendiendo el vector usado.

Requisitos para el puntaje completo:

- Enumera vectores de privesc (SUID, sudo, capabilities, cron, etc.) y **cómo** los encontró.
- Ejecuta la escalada a root con comandos exactos y captura la **root flag**.
- Explica el mecanismo: por qué ese vector permite escalar.

Nivel	Puntos	Qué debe mostrar
Completo	15	Root logrado, mecanismo explicado y evidencia de la flag.
Parcial	10	Root logrado sin explicar el porqué, o enumera el vector pero no lo ejecuta.
Mínimo	5	Intento parcial de escalada.
Ausente	0	No hay escalada documentada.

4. Uso de inteligencia artificial — 20 pts

Núcleo del curso: cómo dirigiste la IA para resolver el reto. La IA ejecuta; la persona dirige y valida.

Requisitos para el puntaje completo:

- Muestra cómo usaste la IA en **cada fase** (prompts relevantes, incluidos o resumidos).
- **Pensamiento crítico**: señala cuándo la IA se equivocó o alucinó y cómo lo verificaste/corregiste.
- Distingue el aporte de la IA del aporte propio (qué decidiste vos).
- Itera: muestra cómo refinaste los prompts cuando la primera respuesta no servía.

Nivel	Puntos	Qué debe mostrar
Completo	20	Uso documentado por fase, evaluación crítica de las respuestas de IA, iteración y distinción humano/IA.
Parcial	12	Usa IA y lo documenta, pero sin evaluación crítica ni iteración visible.
Mínimo	6	Menciona la IA de forma superficial, sin detalle.
Ausente	0	No documenta uso de IA.

5. Herramientas: selección y justificación — 10 pts

Qué herramientas usaste y por qué, no solo una lista.

Requisitos para el puntaje completo:

- Lista las herramientas usadas por fase (recon, explotación, privesc).
- **Justifica** la elección de cada una (por qué esa y no otra).
- Incluye los comandos y flags relevantes.

Nivel	Puntos	Qué debe mostrar
Completo	10	Herramientas por fase, justificadas, con comandos.
Parcial	6	Lista herramientas pero justifica poco.
Mínimo	3	Menciona alguna herramienta sin contexto.
Ausente	0	No documenta herramientas.

6. Evidencias y reproducibilidad — 10 pts

Que otra persona pueda seguir el reporte y reproducir el ataque.

Requisitos para el puntaje completo:

- Capturas y/o salida de comandos en cada paso clave.
- Comandos en texto copiable (no solo imágenes).
- Las **dos flags** visibles en la evidencia.
- Un lector podría reproducir el ataque siguiendo el reporte.

Nivel	Puntos	Qué debe mostrar
Completo	10	Evidencia por paso, comandos copiables, flags visibles, reproducible.
Parcial	6	Evidencia incompleta o solo capturas sin comandos.
Mínimo	3	Evidencia escasa.
Ausente	0	Sin evidencia.

7. Claridad y estructura del reporte — 10 pts

Orden, redacción y formato del documento.

Requisitos para el puntaje completo:

- Estructura lógica por fases, con secciones claras.
- Redacción clara y directa, sin relleno.
- Formato legible: bloques de código, títulos, listas.

Nivel	Puntos	Qué debe mostrar
Completo	10	Bien estructurado, claro y bien formateado.
Parcial	6	Se entiende pero el orden o el formato flojean.
Mínimo	3	Desordenado o difícil de seguir.
Ausente	0	Sin estructura.

Normas de entrega

- Formato de entrega: **PDF obligatorio**. Incluir nombre, fecha y target evaluado.
- Extensión: la necesaria; se valora la concisión, no el relleno.
- Entregar el reporte de proceso del laboratorio de **examen**.

Penalizaciones

- Flags sin evidencia: no se consideran logradas aunque se describan.
- Copiar un write-up ajeno o pegar una solución sin proceso propio: **0** en las categorías afectadas.
- Lograr root sin documentar cómo, con qué IA y con qué herramientas no alcanza el puntaje: prima el reporte de **proceso**.

Bonus opcional (tope 100)

- Documentar y analizar una **ruta alternativa** de explotación (con su razonamiento y evidencia): **+5**, sin superar los 100 puntos.

Uso autorizado de los laboratorios: entornos vulnerables a propósito, solo para fines educativos. No exponer a redes no confiables.